Kestrel Insight Security Whitepaper

Document KR-SEC-002 | Version 2.3 | Effective 2026-01-15 | Owner: Security

1. Security Program

Kestrel Ridge Software operates an information security management system (ISMS) aligned with ISO/IEC 27001. The program is led by the Chief Information Security Officer (CISO), who reports to the Chief Executive Officer.

Security policies are reviewed and approved at least annually. All employees and contractors complete security awareness training during onboarding and annually thereafter, and acknowledge the acceptable use policy.

2. Hosting Infrastructure

Kestrel Insight runs on Amazon Web Services (AWS) in the customer's selected hosting region. Physical security of data centers is the responsibility of AWS and is covered by AWS's own independent audits.

- Production workloads run in isolated virtual private clouds (VPCs) with network segmentation between tiers.
- Public endpoints are protected by a web application firewall (WAF) and AWS Shield for distributed denial-of-service (DDoS) mitigation.
- Production, staging, and development environments are separated in distinct AWS accounts.

FICTIONAL SAMPLE DOCUMENT - Kestrel Ridge Software is not a real company.

3. Data Encryption

All customer data is encrypted at rest using AES-256. Data in transit over public networks is encrypted using TLS 1.2 or higher; older protocol versions are disabled.

Encryption keys are managed in AWS Key Management Service (KMS) and rotated annually. Customer-managed encryption keys (bring your own key) are supported through AWS KMS on the Enterprise and Enterprise Premium editions. If a customer revokes its key, its data becomes unreadable to Kestrel.

4. Tenant Isolation

In the multi-tenant service, customer data is logically separated. Every request carries a tenant identifier that is enforced at the application layer and by row-level security in the database. Document storage uses a separate encrypted storage prefix per tenant.

Enterprise Premium customers may choose a dedicated single-tenant environment with separate compute and database resources.

FICTIONAL SAMPLE DOCUMENT - Kestrel Ridge Software is not a real company.

5. Access Control

Access to production systems follows the principle of least privilege. Engineers receive just-in-time access that is approved through a ticket and expires automatically. Production access requires single sign-on with phishing-resistant hardware security keys. Access rights are reviewed quarterly.

6. Logging and Monitoring

Security events from infrastructure and applications are centralized and monitored 24x7 by the security operations team, with automated alerting for suspicious activity.

Customer audit logs record sign-ins, permission changes, document access, and administrative actions. Customer audit logs are retained for 1 year.

7. Vulnerability Management

- Code and dependencies are scanned continuously for known vulnerabilities.
- An independent third-party penetration test of the Kestrel Insight platform is performed at least annually.
- Critical vulnerabilities are remediated within 7 days and high-severity vulnerabilities within 30 days.
- A penetration test summary letter is available to customers under NDA. Full penetration test reports are not distributed.

FICTIONAL SAMPLE DOCUMENT - Kestrel Ridge Software is not a real company.

8. Incident Response

Kestrel maintains a documented incident response plan that defines roles, severity levels, and escalation paths. The plan is tested at least annually through a tabletop exercise.

Kestrel will notify affected customers of a confirmed security incident involving their data within 72 hours of confirmation.

9. Backup and Recovery

Production databases are backed up daily using encrypted snapshots. Backups are retained for 30 days and are stored in a separate AWS account within the same hosting region. Restore procedures are tested quarterly.

10. Secure Development

- All code changes require peer review before merge.
- Static application security testing (SAST) and secrets scanning run on every pull request.
- Developers complete secure coding training annually.

FICTIONAL SAMPLE DOCUMENT - Kestrel Ridge Software is not a real company.